

Lecture 20 : Other Features of NMAP

Introduction

In the dynamic landscape of cybersecurity, understanding and mitigating vulnerabilities is paramount for protecting digital assets. This session delves into the critical process of vulnerability assessment, a foundational step in identifying potential weaknesses within systems before malicious actors can exploit them. We will explore Nessus, a widely recognized and powerful tool designed to scan networks and systems for security flaws. By learning how to effectively utilize Nessus, students will gain practical insights into uncovering vulnerabilities such as misconfigurations, missing patches, and insecure services. This knowledge is not merely theoretical; it forms the bedrock for developing robust security postures and understanding the initial reconnaissance phase that precedes any attempted penetration. Mastering vulnerability assessment with tools like Nessus is an essential skill for anyone aspiring to secure modern IT infrastructures.

Core Concepts

Term	Definition	Significance
Nessus	A proprietary vulnerability scanner used to identify security weaknesses and misconfigurations in computer systems and networks.	It automates the process of discovering vulnerabilities, providing detailed reports for remediation.
Vulnerability Assessment	The process of identifying, quantifying, and prioritizing vulnerabilities in a system or network.	It provides a snapshot of an organization's security posture, highlighting potential entry points for attackers.
Penetration Testing	The practice of attempting to gain unauthorized access to a system or network to identify exploitable vulnerabilities.	It actively tests the effectiveness of security controls by simulating real-world attacks, confirming exploitability.

Term	Definition	Significance
Target IP Address	The specific network address of a system or device that is being scanned for vulnerabilities.	Essential for directing the scanner to the correct host(s) to be assessed.
Discovery Options	Methods used by Nessus to identify active hosts and services on a network, including ping, ARP, TCP, and ICMP.	Ensures comprehensive scanning by accurately mapping the network topology and active devices.
Port Scanning	The process of identifying open ports on a network host, indicating active services that might be vulnerable.	Crucial for understanding the attack surface of a target system.
Assessment Types	Categories of vulnerability checks performed by Nessus, such as brute force, web application, Windows, and malware assessments.	Allows for tailored scanning based on the specific environment and potential threats.
Plugins	Modular components within Nessus that contain specific vulnerability checks and detection logic.	Enable Nessus to detect a vast array of vulnerabilities and are regularly updated to cover new threats.
Critical Vulnerability	A security flaw that, if exploited, could lead to severe consequences, such as full system compromise or data loss.	Requires immediate attention and remediation due to its high potential impact.
CVE	Common Vulnerabilities and Exposures; a dictionary of publicly known information security vulnerabilities.	Provides a standardized identifier for specific vulnerabilities, aiding in communication and remediation efforts.

Term	Definition	Significance
Bind Shell Backdoor	A type of backdoor where a shell is listening on a remote port without authentication, allowing direct command execution.	Represents a severe security risk, as an attacker can connect and control the system remotely.
MS17-010	A security update addressing vulnerabilities in Microsoft Windows SMB Server, famously exploited by WannaCry.	Highlights the importance of timely patching for critical server components.

Detailed Analysis

1. Initiating a Vulnerability Scan with Nessus

The process of conducting a vulnerability assessment using Nessus begins with accessing the tool and configuring a new scan. Upon logging into the Nessus interface with the appropriate credentials established during installation, users are presented with an option to initiate a "New Scan." Nessus offers a variety of scan templates, each tailored for different assessment needs, including "advance dynamic scan," "advance scan," "audit cloud infrastructure," "badlock detection," and "basic network scan." For a comprehensive and customizable assessment, the "advance scan" option is typically selected.

Once "advance scan" is chosen, the user must provide essential details to define the scan parameters. This includes assigning a descriptive "Name" to the scan, such as "NPTEL," and an optional "Description," like "Demo." The scan results are organized into folders, with "My Scans" being a common default. Crucially, the "Target" field requires the IP addresses of the systems to be scanned. Nessus supports scanning multiple targets simultaneously by listing their IP addresses separated by commas, for example, "192.168.0.104, 192.168.0.106." This flexibility allows for efficient assessment of multiple hosts within a network segment.

2. Configuring Discovery and Assessment Options

Effective vulnerability scanning relies on robust discovery mechanisms to accurately identify active hosts and services. Nessus provides several "Discovery" options to achieve this. These include using "ping method," "ARP," and "TCP" to determine host availability. It also leverages "ICMP" (Internet Control Message Protocol) for host discovery. To ensure thoroughness, Nessus allows setting a "maximum number of

tries," which dictates how many attempts the scanner makes for a particular request; a setting of "2" means it will try twice.

Beyond host discovery, "Port scanning" is a critical component for enumerating local ports and identifying running services. Nessus can be configured to use protocols like "SSH," "WMI" (Windows Management Instrumentation), and "SNMP" (Simple Network Management Protocol) for deeper enumeration. An intelligent feature allows the network port scanner to run only if local port enumeration fails, optimizing scan time. "Service discovery" further enhances the scan by enumerating all "SSL or TLS ciphers," providing insights into cryptographic configurations.

The "Assessment" section allows users to specify the types of vulnerability checks to perform. Options include "Brute force assessment," "web application assessment," "Windows assessment," and "malware assessment." Users can select or deselect these options based on their assessment goals; for instance, one might choose to disable malware scanning if it's not a primary concern for a particular assessment. Additionally, Nessus offers "Report" generation options to customize the output format and content of the scan results.

Advanced settings provide fine-grained control over scan performance and network interaction. These include "network timeout," which defines how long Nessus waits for a response (e.g., "5" seconds), and "maximum simultaneous check per host" (e.g., "5"), which limits the number of concurrent checks against a single target. Similarly, "maximum simultaneous host per scan" (e.g., "5") controls how many hosts are scanned concurrently. These parameters can be adjusted to balance scan speed with network impact. Nessus also relies on a comprehensive set of "plugins," which are pre-installed during setup and contain the logic for detecting various vulnerabilities. These plugins are crucial for the tool's ability to identify a wide range of security flaws. After configuring all desired options, the scan settings are saved.

3. Executing the Scan and Analyzing Results

Once the scan configuration is complete and saved, the assessment is initiated by clicking the "launch" button. The scan process begins and typically takes some time to complete, depending on the number of targets, the scope of the assessment, and network conditions. During this period, Nessus actively probes the target systems, collecting information and identifying potential vulnerabilities based on its extensive plugin database.

Upon completion, Nessus presents a detailed summary of the findings. For the example scan, two systems were targeted: 192.168.0.104 and 192.168.0.106. The results for 192.168.0.104 revealed a total of 70 vulnerabilities, categorized by severity:

- * **Critical:** 9 vulnerabilities
- * **High:** 5 vulnerabilities
- * **Medium:** 23 vulnerabilities
- * **Low:** 8 vulnerabilities
- * **Informational:** 129 items

Detailed vulnerability descriptions are provided, such as "SSL multiple issues" and a "bind shell backdoor detection." The bind shell backdoor is particularly concerning, as it indicates "a shell is listening on the remote port without any authentication being required," allowing an attacker to connect and send commands directly.

The second target, 192.168.0.106, showed a different set of findings:

- * **Critical:** 1 vulnerability
- * **Medium:** 2 vulnerabilities
- * **Informational:** 36 items

A significant critical vulnerability identified on this host was related to "MS17-010 security update for Microsoft Windows SMB server." This refers to a set of vulnerabilities in the Server Message Block (SMB) protocol, famously exploited by ransomware like WannaCry. Specific CVE (Common Vulnerabilities and Exposures) numbers associated with this vulnerability include "CVE 2017-0143," "CVE 2017-0144," "CVE 2017-0145," "CVE 2017-0146," and "CVE 2017-0148." An "information disclosure vulnerability" was also present. Among the medium vulnerabilities, "MS17-047" was noted, indicating an "elevation of privilege vulnerability in the SAM and local security authority" on the remote Windows host. Nessus not only lists these vulnerabilities but also often provides possible solutions or remediation steps.

4. Vulnerability Assessment vs. Penetration Testing

It is crucial to distinguish between vulnerability assessment and penetration testing, as they represent distinct phases in the cybersecurity lifecycle. The process demonstrated with Nessus falls under the "vulnerability assessment phase." In this phase, the primary objective is to "find out all the possible way by which an attacker can penetrate inside the victim machine." It is a discovery process, identifying potential weaknesses without actively exploiting them.

In contrast, "penetration testing" is the subsequent phase. During penetration testing, an attacker (or ethical hacker) "can try with all these vulnerability to check which vulnerability is working and which one is not." This involves actively attempting to exploit the identified vulnerabilities to confirm their existence and determine the extent of potential damage or access that could be gained. While vulnerability assessment identifies what could be exploited, penetration testing proves what can be exploited. The information gathered during the vulnerability

assessment phase serves as the roadmap for the penetration testing phase, guiding the ethical hacker in their attempts to breach the system.

Key Takeaways

- [] Nessus is a powerful tool for conducting vulnerability assessments, identifying security weaknesses in systems and networks.
- [] Configuring a Nessus scan involves specifying scan name, description, target IP addresses (multiple targets separated by commas), and selecting appropriate scan templates.
- [] Discovery options like ping, ARP, TCP, and ICMP are crucial for accurately mapping active hosts and services on a network.
- [] Port scanning and service discovery help enumerate open ports and identify running services, including SSL/TLS ciphers.
- [] Nessus offers various assessment types, including brute force, web application, Windows, and malware assessments, allowing for tailored scans.
- [] Advanced settings control scan performance parameters such as network timeout and maximum simultaneous checks/hosts.
- [] Scan results categorize vulnerabilities by severity (critical, high, medium, low, informational) and provide detailed descriptions, such as bind shell backdoors and specific CVEs like MS17-010.
- [] Vulnerability assessment focuses on identifying potential weaknesses, while penetration testing actively attempts to exploit those weaknesses to confirm their viability.
- [] Timely patching, as highlighted by vulnerabilities like MS17-010, is critical for maintaining system security.
- [] Nessus plugins are essential for its ability to detect a wide array of vulnerabilities and are regularly updated.

Conclusion

The exploration of Nessus for vulnerability assessment underscores its indispensable role in modern cybersecurity practices. By systematically scanning and identifying weaknesses such as unpatched software (e.g., MS17-010), misconfigured services (e.g., SSL issues), and critical backdoors (e.g., bind shells), organizations can proactively address security gaps before they are exploited by malicious actors. This process is not merely about finding flaws; it's about understanding the attack surface, prioritizing risks based on severity, and implementing targeted remediation strategies. The distinction between vulnerability assessment and penetration testing is vital, as the former provides the intelligence that informs the latter's active

exploitation attempts. As we move forward, the insights gained from tools like Nessus will serve as a critical foundation for developing comprehensive security strategies, enabling ethical hackers and security professionals to build more resilient and secure digital environments. The next steps involve leveraging this assessment data to perform actual penetration testing, demonstrating how identified vulnerabilities can be exploited in practice.